

VULNERABILITY ASSESSMENT REPORT

Passive Security Assessment

Target Website:	samihzs.in
Assessment Type:	Passive Vulnerability Assessment
Assessment Date:	02 May 2026
Prepared By:	Shaik Sami Hassan
Organization:	Future Interns – Cyber Security Internship
Report Version:	1.0

CONFIDENTIALITY NOTICE: This document contains security assessment findings and is intended solely for authorized personnel. Distribution or disclosure to unauthorized parties is prohibited.

Executive Summary

This report presents the findings of a passive vulnerability assessment conducted on **samihzs.in**, a personal web asset hosted on GitHub Pages infrastructure. The assessment was performed as part of the Future Interns Cyber Security Internship program and follows industry-standard passive reconnaissance methodologies.

The objective of this assessment was to identify potential security vulnerabilities and configuration weaknesses that could expose the website and its users to security risks. The assessment scope was limited to passive, read-only analysis techniques, ensuring no disruption to service availability or data integrity.

The assessment revealed **two primary security concerns** that warrant remediation:

1. Missing Security Headers (MEDIUM Risk): Critical HTTP security headers are absent, potentially exposing users to cross-site scripting (XSS), clickjacking, and MIME-sniffing attacks.

2. Insecure HTTP Access (HIGH Risk): The website does not enforce HTTPS-only access, allowing plaintext HTTP connections that are vulnerable to man-in-the-middle attacks and traffic interception.

While the website demonstrates basic security hygiene with HTTPS availability and standard port configurations, the identified vulnerabilities could compromise user security and data confidentiality. Immediate remediation of the high-risk finding and timely implementation of security headers are recommended to establish a robust security posture.

Risk Level	Finding Count	Priority
HIGH	1	Immediate
MEDIUM	1	Short-term
LOW	0	Routine
INFORMATIONAL	1	Monitoring

Assessment Scope and Methodology

Scope of Assessment

Target: samihzs.in (personal web asset, authorized for assessment)

Assessment Type: Passive Vulnerability Assessment (Read-Only)

Assessment Date: 02 May 2026

Authorization: Authorized personal asset owned by the assessor

Ethical and Legal Compliance

This assessment was conducted in strict compliance with ethical hacking principles and legal boundaries. Only passive reconnaissance techniques were employed. No exploitation attempts, brute force attacks, login testing, directory fuzzing, denial-of-service testing, or any intrusive activities were performed. The assessment was limited exclusively to publicly accessible resources and information.

Tools and Technologies Used

Tool	Purpose	Version/Platform
Kali Linux	Security assessment platform	2024.x
Nmap	Network reconnaissance and port scanning	7.94+
Browser Developer Tools	HTTP header inspection	Chrome/Firefox
SecurityHeaders.com	Security header analysis	Online Service
Curl	HTTP/HTTPS protocol testing	Command-line utility

Assessment Methodology

Phase 1 - Information Gathering: Network reconnaissance using Nmap to identify open ports, services, and hosting infrastructure.

Phase 2 - Security Header Analysis: Evaluation of HTTP security headers using browser developer tools and SecurityHeaders.com to identify missing security controls.

Phase 3 - Transport Security Testing: Validation of HTTPS implementation and HTTP-to-HTTPS redirection using Curl and browser-based testing.

Phase 4 - Risk Assessment: Classification of findings based on potential business impact and likelihood of exploitation.

Target Overview and Network Analysis

Target Information

Domain Name	samihzs.in
Hosting Provider	GitHub Pages / GitHub CDN
Primary Function	Personal website / Portfolio
Hosting Type	Static site hosting
Infrastructure	Cloud-based CDN

Network Reconnaissance Findings

Command Executed:

```
nmap -Pn -sV samihzs.in
```

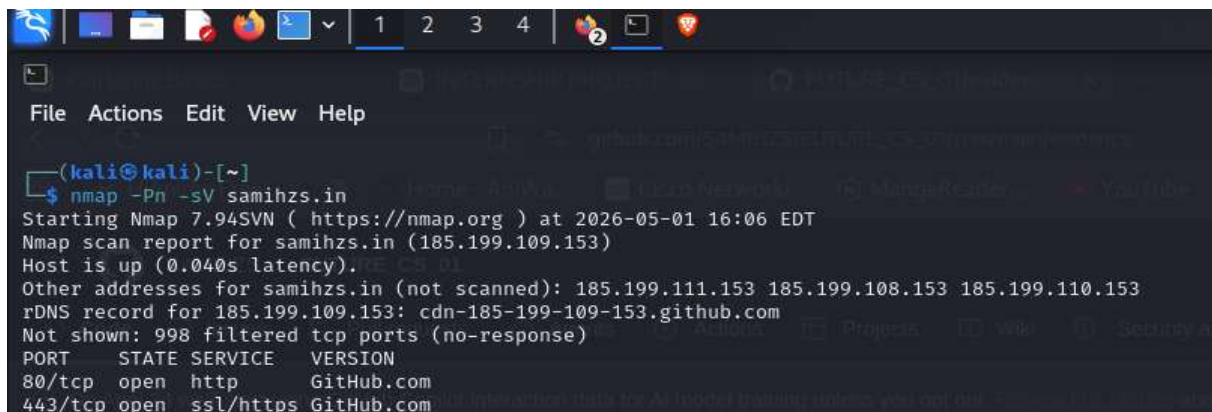
Port Scan Results:

Port	State	Service	Remarks
80/tcp	Open	HTTP	Standard web port (unencrypted)
443/tcp	Open	HTTPS	Encrypted web traffic

Analysis:

The network scan revealed standard web service ports (80 and 443) in an open state, resolving to GitHub's content delivery network. This configuration is typical for GitHub Pages hosting and indicates that both encrypted (HTTPS) and unencrypted (HTTP) connections are accepted. The presence of both ports without enforced redirection presents a security concern addressed in Finding #2.

Risk Classification: INFORMATIONAL / LOW



```
(kali㉿kali)-[~]
$ nmap -Pn -sV samihzs.in
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-01 16:06 EDT
Nmap scan report for samihzs.in (185.199.109.153)
Host is up (0.040s latency).
Other addresses for samihzs.in (not scanned): 185.199.111.153 185.199.108.153 185.199.110.153
rdNS record for 185.199.109.153: cdn-185-199-109-153.github.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http   GitHub.com
443/tcp    open  ssl/https GitHub.com
```

Figure 1: Nmap service detection results for samihzs.in

Finding #1: Missing Security Headers

Risk Level	MEDIUM
CVSS Score	5.3 (Estimated)
Category	Security Misconfiguration
Attack Vector	Network / Browser

Description

Analysis of HTTP response headers using browser developer tools and SecurityHeaders.com revealed a complete absence of critical security headers. The website received a security grade of **F** from SecurityHeaders.com, indicating minimal browser-level security protections. Modern web applications rely on HTTP security headers to instruct browsers on how to handle potentially malicious content and enforce security policies.

Missing Security Headers

Missing Header	Security Impact
Content-Security-Policy (CSP)	Allows execution of malicious scripts; no XSS protection policy
X-Frame-Options	Website can be embedded in frames (clickjacking vulnerability)
X-Content-Type-Options	Browser may incorrectly interpret file types (MIME sniffing attacks)
Referrer-Policy	Sensitive URL data may lead to third-party sites
Permissions-Policy	No restrictions on browser features (camera, microphone, geolocation)

Business Impact

The absence of security headers increases the website's attack surface and exposes visitors to client-side attacks. Potential exploitation scenarios include cross-site scripting (XSS) attacks where malicious JavaScript could be injected, clickjacking attacks that trick users into clicking hidden elements, and MIME-type confusion attacks. While the likelihood of exploitation depends on additional factors, the lack of defense-in-depth controls represents a significant gap in the security posture.

Recommendations

- Implement a **Content-Security-Policy** header with a restrictive policy (e.g., default-src 'self') to mitigate XSS risks.
- Add **X-Frame-Options: DENY** or **SAMEORIGIN** to prevent clickjacking attacks.
- Include **X-Content-Type-Options: nosniff** to prevent MIME-type sniffing.

- Configure **Referrer-Policy**: **no-referrer** or **strict-origin-when-cross-origin** to control referrer information leakage.
- Implement **Permissions-Policy** to restrict access to sensitive browser features.

Platform Considerations

Note: GitHub Pages has inherent limitations regarding custom HTTP header configuration. Implementation may require the use of a custom domain with Cloudflare or similar reverse proxy service, or migration to a hosting platform with greater configuration flexibility.

The screenshot shows the Security Headers tool interface. At the top, there's a search bar with the URL `https://samihzs.in/` and a 'Scan' button. Below the search bar, there are checkboxes for 'Hide results' and 'Follow redirects'. The main content area is divided into three sections: 'Security Report Summary', 'Missing Headers', and 'Raw Headers'.

Security Report Summary

The summary shows a red 'F' grade. The site is `https://samihzs.in/`, the IP address is `185.199.110.153`, and the report time is `01 May 2026 19:40:16 UTC`. The headers section lists the following missing headers: `Strict-Transport-Security`, `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Referrer-Policy`, and `Permissions-Policy`. The advanced section states: 'Ouch, you should work on your security posture immediately.' with a 'Start Now' button.

Missing Headers

This section provides detailed information about the missing headers:

- Strict-Transport-Security**: HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".
- Content-Security-Policy**: Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
- X-Frame-Options**: X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
- X-Content-Type-Options**: X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
- Referrer-Policy**: Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
- Permissions-Policy**: Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Raw Headers

This section displays the raw headers for the site:

Header	Value
HTTP/2	200
server	GitHub.com
content-type	text/html; charset=utf-8
last-modified	Sun, 19 Apr 2026 18:46:27 GMT
access-control-allow-origin	*
etag	W/"69e52303-55a5"
expires	Fri, 01 May 2026 19:50:16 GMT
cache-control	max-age=600
content-encoding	gzip
x-proxy-cache	MISS
x-github-request-id	EBDE:2B694F:F26F:15AD6:69F50192
accept-ranges	bytes
age	0
date	Fri, 01 May 2026 19:40:16 GMT
via	1.1 varnish
x-served-by	cache-dub4372-DUB
x-cache	MISS
x-cache-hits	0
x-timer	S1777664417.550474,V50,VE117
vary	Accept-Encoding
x-fastly-request-id	384afa065fe0655decc73cfaac047d2b96ab8e61
content-length	4575

Figure 2: Security Headers detection results for samihzs.in

Finding #2: Missing HTTP-to-HTTPS Redirect

Risk Level	HIGH
CVSS Score	7.4 (Estimated)
Category	Insecure Transport / Encryption
Attack Vector	Network (Man-in-the-Middle)

Description

Testing with the Curl utility revealed that the website accepts HTTP connections on port 80 and serves content without automatically redirecting users to the secure HTTPS version. When accessing **http://samihzs.in**, the server responds with HTTP 200 OK instead of the expected HTTP 301 or 302 redirect to **https://samihzs.in**.

Technical Evidence

Command Executed:

```
curl -I http://samihzs.in
```

Response Received:

```
HTTP/1.1 200 OK
```

Expected Secure Response:

```
HTTP/1.1 301 Moved Permanently  
Location: https://samihzs.in/
```

Security Impact

Allowing unencrypted HTTP connections exposes users to several serious security threats:

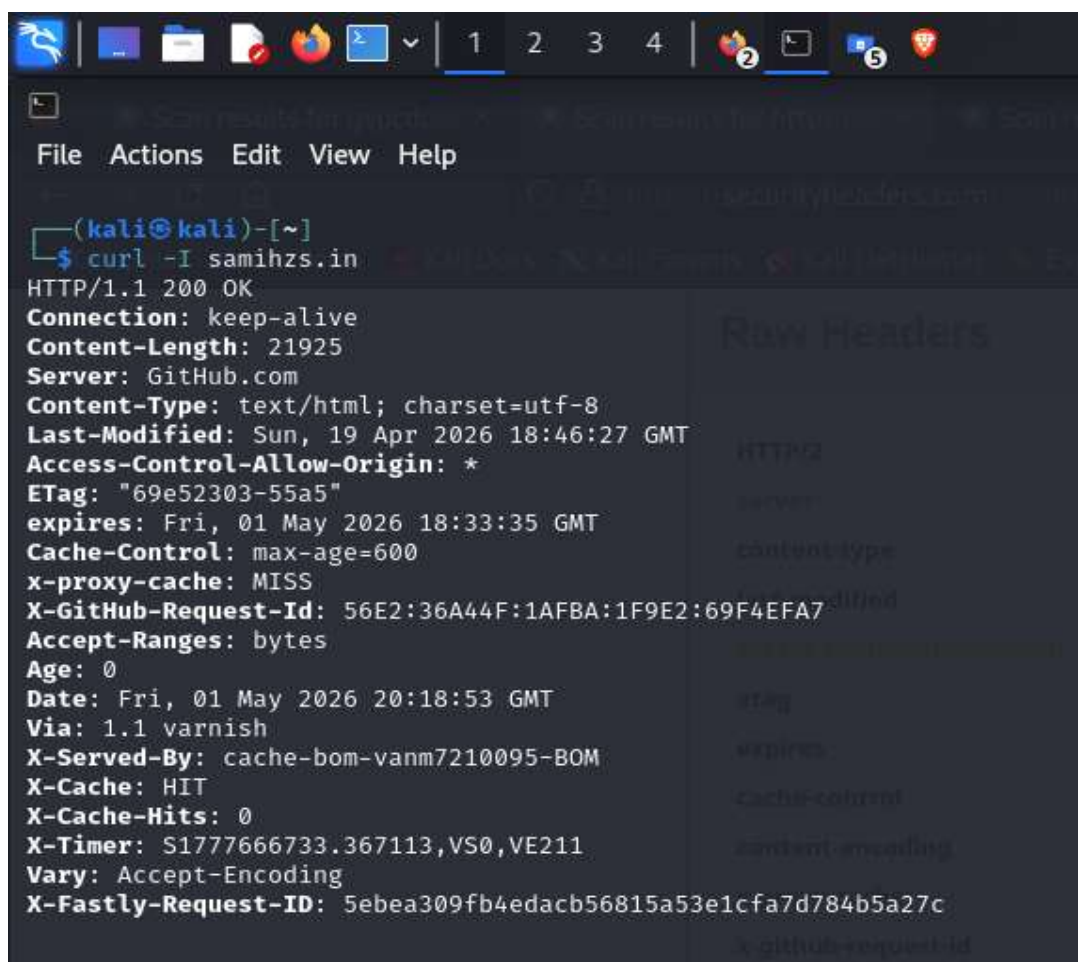
- **Man-in-the-Middle (MitM) Attacks:** Attackers on the same network (e.g., public Wi-Fi) can intercept, read, and modify HTTP traffic in transit.
- **SSL Stripping:** Malicious actors can downgrade HTTPS connections to HTTP, defeating encryption protections.
- **Data Exposure:** Any data transmitted over HTTP, including form submissions or session tokens, is visible in plaintext.
- **Content Injection:** Attackers can inject malicious scripts or content into unencrypted responses.

Business Impact

This vulnerability directly threatens user confidentiality and data integrity. Users accessing the site over insecure networks are particularly vulnerable. Modern browsers display security warnings for HTTP sites, which may erode user trust. Additionally, search engines penalize sites without proper HTTPS enforcement in their rankings.

Recommendations

- **Immediate Action:** Configure automatic HTTP-to-HTTPS redirection at the hosting provider level (GitHub Pages settings).
- Verify that HTTPS enforcement is enabled in the GitHub repository settings under Pages configuration.
- Implement **HTTP Strict Transport Security (HSTS)** header to instruct browsers to only use HTTPS connections.
- Consider using a CDN or reverse proxy (e.g., Cloudflare) for enhanced HTTPS enforcement and additional security features.
- Test redirection from multiple network environments to ensure consistent behavior.



```
(kali@kali)-[~]
$ curl -I samihzs.in
HTTP/1.1 200 OK
Connection: keep-alive
Content-Length: 21925
Server: GitHub.com
Content-Type: text/html; charset=utf-8
Last-Modified: Sun, 19 Apr 2026 18:46:27 GMT
Access-Control-Allow-Origin: *
ETag: "69e52303-55a5"
expires: Fri, 01 May 2026 18:33:35 GMT
Cache-Control: max-age=600
x-proxy-cache: MISS
X-GitHub-Request-Id: 56E2:36A44F:1AFBA:1F9E2:69F4EFA7
Accept-Ranges: bytes
Age: 0
Date: Fri, 01 May 2026 20:18:53 GMT
Via: 1.1 varnish
X-Served-By: cache-bom-vanm7210095-BOM
X-Cache: HIT
X-Cache-Hits: 0
X-Timer: S1777666733.367113,VS0,VE211
Vary: Accept-Encoding
X-Fastly-Request-ID: 5ebea309fb4edacb56815a53e1cfa7d784b5a27c
```

Raw Headers

HTTP/1.1
server:
content-type:
last-modified:
access-control-allow-origin:
etag:
expires:
cache-control:
content-encoding:
x-github-request-id:

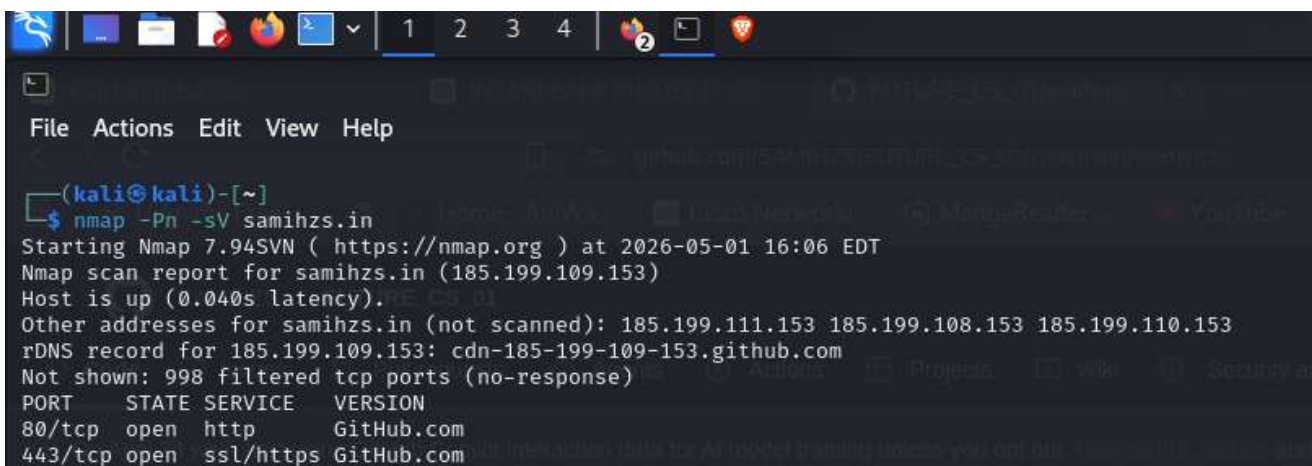
Figure 3: CURL detection results for samihzs.in

Evidence and Validation

This section contains placeholders for technical evidence supporting the findings documented in this report. Screenshots and command outputs should be inserted here for complete documentation.

Evidence 1: Nmap Network Scan

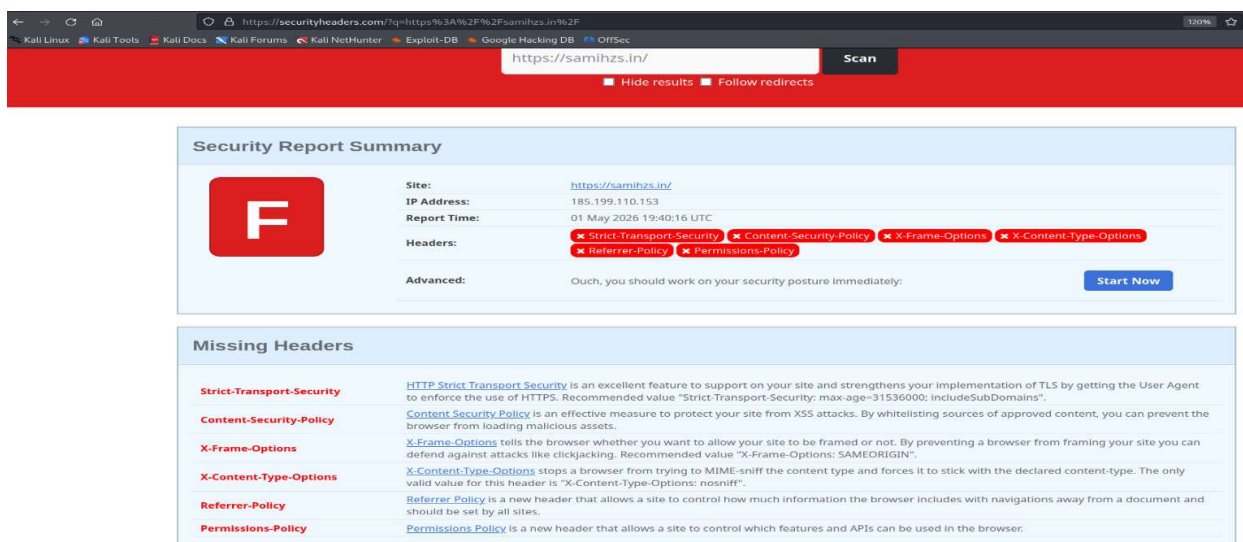
Description: Screenshot of Nmap scan results showing open ports 80 and 443, service identification, and GitHub infrastructure detection.



```
(kali㉿kali)-[~]
$ nmap -Pn -sV samihzs.in
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-05-01 16:06 EDT
Nmap scan report for samihzs.in (185.199.109.153)
Host is up (0.040s latency).
Other addresses for samihzs.in (not scanned): 185.199.111.153 185.199.108.153 185.199.110.153
rDNS record for 185.199.109.153: cdn-185-199-109-153.github.com
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         GitHub.com
443/tcp    open  ssl/https    GitHub.com
```

Evidence 2: SecurityHeaders.com Analysis

Description: Screenshot from SecurityHeaders.com showing grade F and listing all missing security headers with detailed explanations.



Security Report Summary

Site: <https://samihzs.in/>

IP Address: 185.199.110.153

Report Time: 01 May 2026 19:40:16 UTC

Headers: ✖ Strict-Transport-Security ✖ Content-Security-Policy ✖ X-Frame-Options ✖ X-Content-Type-Options ✖ Referrer-Policy ✖ Permissions-Policy

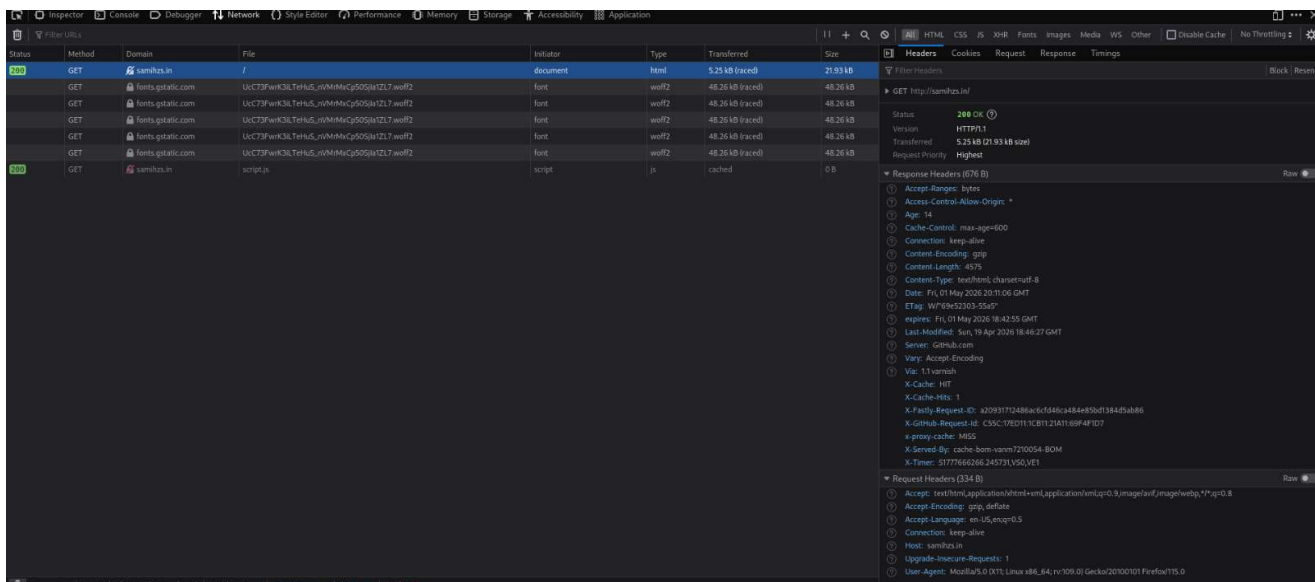
Advanced: Ouch, you should work on your security posture immediately. [Start Now](#)

Missing Headers

Strict-Transport-Security	HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; IncludeSubDomains".
Content-Security-Policy	Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.
X-Frame-Options	X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".
X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

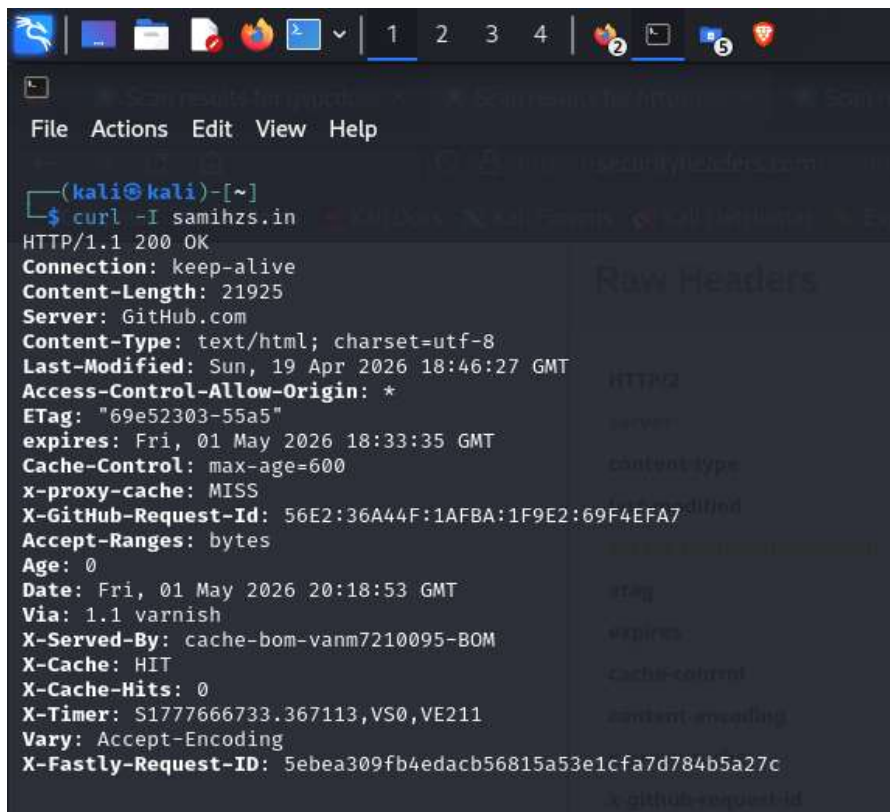
Evidence 3: Browser Developer Tools Header Inspection

Description: Screenshot of browser developer tools (Network tab) showing HTTP response headers with absence of security headers.



Evidence 4: Curl HTTP Response Test

Description: Screenshot of terminal showing curl -I http://samihzs.in command output with HTTP 200 OK response instead of 301 redirect.



Validation Notes

All security testing activities documented in this report were performed on 02 May 2026 using a dedicated Kali Linux virtual lab environment hosted on Oracle VirtualBox.

To ensure result accuracy and consistency, multiple validation methods were used during the assessment:

Network reconnaissance findings were validated using Nmap service detection and repeated scans where required.

Browser-based HTTP response analysis was manually verified using Developer Tools (Network and Header inspection).

Security header configurations were independently cross-validated using SecurityHeaders.com.

Transport security behavior was manually confirmed using Curl command-line testing to verify HTTP and HTTPS responses.

All identified findings were observed consistently across multiple testing attempts during the assessment period.

Environmental factors such as CDN caching behavior, GitHub Pages infrastructure responses, browser caching, and network routing may influence certain HTTP responses. However, the core findings documented in this report remained consistent during validation.

No active exploitation, authentication testing, payload injection, directory brute forcing, or service disruption techniques were used during this assessment.

This assessment remained fully aligned with ethical security testing principles and the passive assessment scope defined by the Future Interns Cyber Security Internship program.

Conclusion and Remediation Priorities

Security Posture Summary

The passive vulnerability assessment of **samihzs.in** identified critical security configuration gaps that expose the website and its users to preventable security risks. While the site benefits from GitHub Pages' reliable infrastructure and has HTTPS capability enabled, the lack of enforced secure transport and absence of browser security controls create vulnerabilities that could be exploited by malicious actors.

The assessment revealed one high-risk finding and one medium-risk finding, both of which are remediable through configuration changes without requiring code modifications or architectural redesign. The vulnerabilities identified represent common security misconfigurations rather than software defects, making remediation straightforward once platform limitations are addressed.

Remediation Priorities

Priority	Finding	Action Required
1 (Critical)	Missing HTTP-to-HTTPS Redirection	Enable HTTPS enforcement in GitHub
2 (High)	Missing Security Headers	Configure security headers via reverse

Platform-Specific Considerations

GitHub Pages provides excellent hosting reliability and CDN performance but imposes limitations on security header customization. To fully address the identified vulnerabilities, the following options should be evaluated:

- **Option 1:** Implement Cloudflare or similar CDN as a reverse proxy to add security headers and enforce HTTPS.
- **Option 2:** Migrate to a hosting platform with native support for custom HTTP headers (e.g., Netlify, Vercel).
- **Option 3:** Accept security header limitations while implementing HTTPS enforcement as an immediate mitigation measure.

Ongoing Security Recommendations

- Conduct regular vulnerability assessments on a quarterly basis to identify new security issues.
- Monitor security advisories related to GitHub Pages infrastructure and web security best practices.
- Implement automated security scanning tools in the deployment pipeline for continuous monitoring.
- Stay informed about emerging web security standards and update configurations accordingly.
- Document all security-related configuration changes and maintain an audit trail.

Final Statement

This assessment was conducted with diligence and professionalism as part of the Future Interns Cyber Security Internship program. The findings presented in this report reflect observable security gaps based on industry-standard assessment methodologies. Implementation of the recommended remediation measures will significantly enhance the security posture of samihzs.in and better protect its users from common web-based threats.

Shaik Sami Hassan

Cyber Security Analyst Intern

Future Interns – Cyber Security Internship

Date: 02 May 2026